AI 应用安全评审清单

> 本文件是**虚构的演示语料**：清单条目与期限均为自编， 仅用于本地检索链路演示与评测。

1. 提示注入

检索到的文档内容一律视为不可信输入。系统提示不得直接拼接文档中的指令性语句， 文档只作为引用材料出现。发现文档中出现「忽略以上要求」类语句时，应在清洗阶段标记并降权， 同时记一条审计日志。工具调用结果同样按不可信输入处理。

2. 个人信息与日志

日志写入前做脱敏：手机号、身份证号与邮箱地址用占位符替换。评估语料不得包含真实个人信息， 需要真实数据时必须先做去标识化并取得书面授权。导出任何包含用户内容的文件都要走审批， 审批记录保留 180 天。

3. 权限校验

权限必须在服务端校验，客户端传来的档位只作为「请求」，最终以服务端签发的身份为准， 默认拒绝。低档位用户的检索结果集中不得出现高档位文档块，这一条必须在检索层实现， 不能只在提示词里要求模型不要回答。越权访问尝试记录审计日志并告警。

4. 输出与工具安全

模型输出不得直接拼接成 SQL、命令行或文件路径执行。工具调用使用白名单， 每个工具声明参数模式与超时。输出过滤至少覆盖三类内容：可执行的代码块、内网地址、密钥形态的字符串。 被过滤的内容在日志中留原文哈希，不留原文。

5. 依赖与密钥

依赖每月扫描一次，高危漏洞 7 天内修复，中危 30 天内修复。密钥不得进入代码仓库与日志， 轮换周期 90 天；轮换时必须保证旧密钥在 24 小时内仍可用，避免发布中断。 仓库启用推送保护，命中密钥规则的推送直接拒绝。

6. 演练与评审

每半年做一次红队演练，覆盖越权、注入与数据外泄三类场景。新功能上线前完成安全评审， 评审清单至少包括：数据来源、权限边界、日志脱敏、工具白名单与回滚方案。 评审记录随发布看板归档，缺失评审记录的功能不允许上线。